
A Case Study in Assuring AI-Written Software

Lindsey Ferris
Independent Researcher

Sierra Bonilla
University College London
London, United Kingdom
sierra.bonilla.21@ucl.ac.uk

Abstract

Software-engineering agents can enable people without formal software training to build systems they could not otherwise implement and simultaneously can produce more code than even experts can meaningfully inspect. In both cases, exhaustive code review is not reliable as the sole basis for human control. We report a case study of a production healthcare platform built through coding agents and governed by an operator without formal software-engineering training. Over time, its workflow grew into a human-led meta-agent system where one agent wrote code, other agents supervised and reviewed it, and project rules carried lessons forward. The operator found that tests, monitors and reviewing agents used to supervise the system were fallible. Some monitors measured proxies rather than outcomes, some audits failed silently, missing checks disappeared from reported results and one automated repair caused operational disruption. In this case, human control depended on keeping the intended outcome, the evidence used to judge it, the agents’ permissions and the final human decision were all tied to the same underlying objective.

1 Introduction

Despite the name, a coding ‘agent’ is really a loop of interacting processes in which a model proposes an action, a harness executes it through tools and returns an observation, and the model iterates until the task is submitted or terminated [Yang et al., 2024]. Its reliability ultimately depends on whether the generated code produces the outcome the user wanted. But when the request is underspecified or the outcome is difficult to measure (i.e. “a pretty website”), the model cannot directly optimize for it. In practice, direct line by line code review of the model output is often treated as the main form of human oversight. However, recent work suggests that experienced developers instead control coding agents through prompting, planning approval, and validation [Huang et al., 2025]. One participant in a practitioner study reported that a week’s commits had grown from a few hundred lines before coding agents to 10–20K after, while another described pull-request backlogs because generation outpaced review [Lyu et al., 2026]. Another study found that coding agents improved initial task completion but reduced code comprehension, and their initial advantage largely disappeared on a later extension task completed without the coding agent [Balepur et al., 2026]. These results do not make source review obsolete, but they motivate complementary controls when exhaustive inspection cannot keep pace.

There is a useful historical precedent. FORTRAN replaced large amounts of hand-written machine code with automatic translation and widened access to programming [Backus et al., 1957]. As checking every generated machine instruction became less practical, assurance shifted toward correctness proofs [McCarthy and Painter, 1967], conformance test suites [Holberton and Parker, 1973], per-translation validation [Pnueli et al., 1998], verified compilers [Leroy, 2009] and randomized differential testing [Yang et al., 2011]. Coding agents are not compilers: they infer underspecified intent, act in stateful environments and may modify their own tests. They are also often proprietary

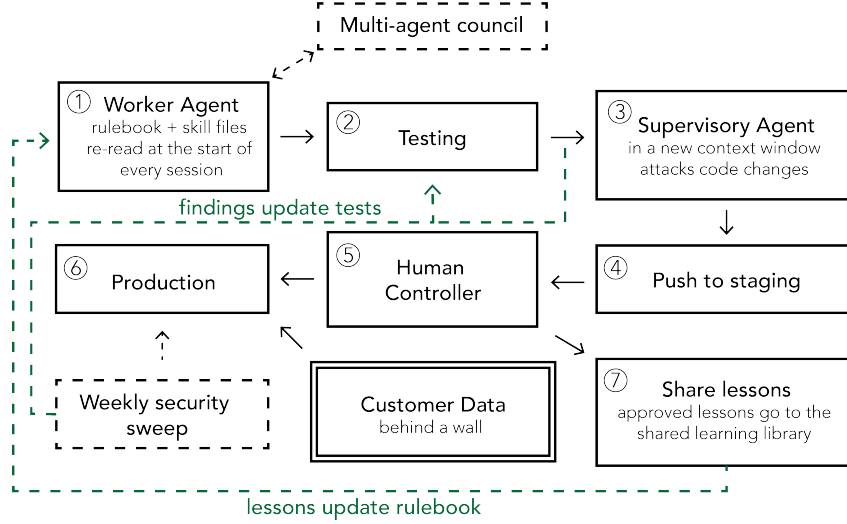


Figure 1: Human-mediated meta-agent workflow used in the case study. The dashed teal arrows are the looping information where lessons update the rulebook and confirmed findings become tests.

and difficult to inspect directly. The analogy is limited, but the precedent is still useful: when direct inspection becomes impractical, assurance may need to move elsewhere.

We examine this question through a boundary case in which an operator without formal SE training used a coding agent as the primary developer of a production healthcare platform that she could not have implemented alone. Because exhaustive source-code review was not a realistic form of oversight, the case provides an opportunity to study what other forms of control emerged in practice. The supervisory workflow was not designed in advance. It developed through trial and error as failures revealed weaknesses and prompted new checks and review practices. Recent research provides the language of evaluation-driven development for describing parts of this evolving workflow [Xia et al., 2025, Lyu et al., 2026].

Using two structured interviews with the operator together with project records, we examine two questions: **RQ1: Where did human control reside when implementation and review were delegated to agents?** **RQ2: What did the resulting checks and reviewing agents contribute, and where did they fail?**

2 Case and workflow

This retrospective case study draws on two structured interviews with the operator, conducted in June and August 2026, together with project records spanning six months. The records included decision logs, audit reports, incident records, check inventories and working notes. We reconstructed the development and assurance workflow from these sources and identified incidents in which an assurance mechanism produced incomplete or misleading evidence. Interview claims were cross-checked against available project records where possible.

The platform supported the business operations of a healthcare practice, including note-taking support, scheduling and payroll workflows, alongside background functions such as access control, backups and audits. Some parts were easy for the operator to inspect: she could try a page or workflow in staging and judge whether it behaved as intended. Other properties were largely hidden from her. She could not directly see whether a backup was usable or whether an audit had run completely. Requirements of a regulated healthcare setting (US health-privacy law) applied, although we do not assess compliance. For context, the HIPAA Security Rule sets administrative, physical and technical safeguards for electronic protected health information, and NIST SP 800-66 provides implementation guidance [U.S. Department of Health and Human Services, 2026, Marron, 2024]. Coding agents could access repositories, test data and staging systems, but production data was kept outside their reach through the system architecture and file and folder permissions.

Figure 1 shows the full workflow. At the start of each session, the primary coding agent re-read a versioned project rulebook, current task and issue lists and reusable skill files, allowing project context and recurring procedures to carry across otherwise fresh sessions. As she explained, *“That’s how the lessons and unfinished work stick even though each session starts fresh.”* The operator described the feature she wanted and approved or revised the proposed approach before implementation. Changes then passed project tests, were reviewed by a separate agent in a fresh context and were deployed to private staging for human inspection. The separate reviewer functioned as an LLM critic [McAleese et al., 2024]. The operator could also commission broader fresh context meta-audits that were not tied to a particular code change. These audits used newly instantiated agents without the primary development conversation to inspect wider parts of the system and its records for problems missed by the normal development loop. Their findings entered the same process of remediation, regression testing and reusable lessons.

For difficult decisions, the operator could invoke a multi-model council. Models from several providers independently answered the same brief without seeing one another’s responses and returned their recommendations, reasons and risks for the operator to consider. Confirmed failures were used to search for similar problems elsewhere in the codebase and, where appropriate, to add regression tests. Agents could also propose reusable lessons at the end of a session; approved lessons were stored for use in later sessions. Production data was inaccessible to the coding agents, and changes reached production only after staging and explicit operator approval.

3 RQ1: Where did human control reside when implementation and review were delegated to agents?

The clearest pattern was asymmetric delegation. The operator delegated implementation and much of its technical review, but not the authority to make consequential changes. Worker and reviewing agents could propose code, findings and persistent lessons, while the operator controlled what became durable project context and what entered production; production data was also kept outside agent reach. Control was concentrated at the points where agent outputs became persistent or operationally consequential, rather than exercised continuously through line-level inspection. This resembles Barnes et al.’s framing of agentic Continuous Integration and Continuous Deployment (CI/CD) as an authority-transfer problem, with control-plane authority separated from bounded data-plane work [Barnes et al., 2026]. It also aligns with architectural tactics such as checkpoints, tool fencing and write staging for high-consequence actions [Safin and Balta, 2026].

This also changed what the operator needed to understand. She did not need to reconstruct every implementation decision, but she did need to know what each reviewing mechanism had observed, what claim its output could support and what action could follow from it. In this case, adding another reviewer moved rather than removed part of the oversight problem: the operator also had to judge the reviewer’s evidential scope and authority. RQ2 examines what happened when those supervisory signals were themselves unreliable.

4 RQ2: What did the resulting checks and reviewing agents contribute, and where did they fail?

When bugs or failures were discovered, they were used to improve later development. When a problem was confirmed, the agent was asked to fix it, look for similar problems elsewhere and record any lesson that should carry forward. The operator became particularly concerned with whether these tests could genuinely detect the failures they claimed to cover: *“I don’t trust a test just because it passes.”* Tests were checked by deliberately recreating targeted failures and confirming that the corresponding checks failed. This uses the broader fault-seeding intuition behind mutation testing [Jia and Harman, 2011]. This is important for LLM-generated tests, because incorrect code in the prompt can substantially reduce test accuracy and bug-detection effectiveness [Huang et al., 2026]. Over time, failures changed not only the code but also the tests and instructions used in later work, similar to evaluation-driven development [Xia et al., 2025, Lyu et al., 2026].

We also asked whether the checks accumulated through incidents and adversarial reviews covered security concerns recognized independently outside the project. The inventory was mapped against four external references that had not been consulted during its construction: the OWASP Top 10,

OWASP Top 10 API Security Risks, CWE Top 25 and relevant HIPAA Security Rule provisions [OWASP Foundation, 2025, 2023, The MITRE Corporation, 2025, Electronic Code of Federal Regulations, 2026]. Of 84 mapped items, 69 (82.1%) were covered by the pre-existing checks. This suggests that the system she developed had accumulated checks addressing many concerns represented in established security guidance. It does not establish full platform security. It also does not demonstrate model generalization: because the standards are public, independence from model training cannot be assumed, a concern in benchmark-contamination research [Zhang et al., 2024].

However, the main finding was that these evaluations themselves became another fallible software layer. Several backup monitors checked whether intermediate events occurred without establishing that a usable backup actually existed. An audit stopped running without producing a failure, while another report calculated its pass rate only from checks that emitted results, allowing missing checks to disappear from the total. In the most consequential incident, a monitor incorrectly classified legitimate long-running work as a failure and repeatedly attempted an automated repair, causing operational disruption. These incidents are related to the test-oracle problem; even when a check executes, its verdict may not establish the intended outcome [Barr et al., 2015]. In each case, a reassuring signal supported a stronger claim than the evidence justified.

These incidents highlighted four recurring concerns in this case: whether a check observed the intended outcome rather than a convenient proxy; whether there was evidence that it had actually run; whether missing or empty results remained visible; and whether its authority was limited enough to prevent an incorrect result from immediately triggering harmful action. The checks and reviewing mechanisms supported later development, but their presence or apparent success was not itself sufficient evidence of reliability.

5 Discussion and limitations

This case is consistent with the broader finding that coding agents reorganize SE work rather than remove it. As implementation becomes easier, more human effort moves toward defining requirements, checking results and deciding whether a change is safe to release [Lyu et al., 2026]. The case adds a distinction between outcomes the operator could inspect directly and those accessible only through software-generated evidence. Staging worked well for observable behavior, while the clearest assurance failures occurred in less visible properties such as backups, audit execution, monitoring completeness and automated recovery.

Researchers have proposed guard agents that check other agents [Xiang et al., 2025], critic models that help humans identify mistakes [McAleese et al., 2024], and execution systems that preserve structured, reversible traces for meta-agent inspection and replay [Yu et al., 2026]. The incidents here raise a complementary issue for meta-agent research: once supervision itself is delegated, human oversight also has to account for what the supervisor observed, what its output actually supports and what authority follows from it. In this case, additional reviewers and monitors were useful, but their outputs could not be treated as ground truth.

Limitations and responsible use. This is a single case involving one operator, one platform and an evolving workflow. The operator was directly involved in creating both the system and its governance process, which may have led to an overly favourable interpretation. We reduced this risk by comparing the interview account with project records and focusing on concrete failures, but the evidence remains observational. The study does not establish that the workflow caused fewer defects, that the platform was secure or compliant, or that the same approach would be sufficient for other users or systems.

6 Conclusion

This case illustrates one way human control was maintained when implementation and much of its review were delegated to agents. In this workflow, control became concentrated around intended outcomes, evidence, access boundaries and consequential decisions. The same workflow also exposed a second-order assurance problem. The tests and reviewing agents introduced to support oversight could provide incomplete or misleading evidence. In this case, adding supervisory mechanisms moved part of the oversight problem to judging what those mechanisms had actually observed, what their outputs supported and what authority followed from them.

References

- John W. Backus, Robert J. Beeber, Sheldon Best, Richard Goldberg, Lois M. Haibt, Harlan L. Herrick, Robert A. Nelson, David Sayre, Peter B. Sheridan, H. Stern, Irving Ziller, Robert A. Hughes, and R. Nutt. The FORTRAN automatic coding system. In *Proceedings of the Western Joint Computer Conference*, pages 188–198, 1957. doi: 10.1145/1455567.1455599.
- Nishant Balepur, Connor Baumler, Valerie Chen, Eunsol Choi, Rachel Rudinger, and Jordan Lee Boyd-Graber. (Im)Paired Programming: Coding agents improve productivity but harm understanding. *arXiv preprint arXiv:2607.26375*, 2026. doi: 10.48550/arXiv.2607.26375. URL <https://arxiv.org/abs/2607.26375>. In-progress preprint.
- Marcus Emmanuel Barnes, Taher A. Ghaleb, and Safwat Hassan. From assistance to agency: Rethinking autonomy and control in CI/CD pipelines. In *Proceedings of the 3rd ACM International Conference on AI-Powered Software*, AIware ’26, pages 96–100, New York, NY, USA, 2026. Association for Computing Machinery. doi: 10.1145/3805760.3814897.
- Earl T. Barr, Mark Harman, Phil McMinn, Muzammil Shahbaz, and Shin Yoo. The oracle problem in software testing: A survey. *IEEE Transactions on Software Engineering*, 41(5):507–525, 2015. doi: 10.1109/TSE.2014.2372785.
- Electronic Code of Federal Regulations. 45 CFR Part 164, Subpart C—Security Standards for the Protection of Electronic Protected Health Information. <https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C>, 2026. Current through 31 August 2026; accessed 2 September 2026.
- Frances E. Holberton and Elizabeth G. Parker. NBS FORTRAN test programs version 1 and version 3. Technical Report NBS IR 73-250, National Bureau of Standards, 1973.
- Dong Huang, Jie M. Zhang, Mark Harman, Mingzhe Du, and Heming Cui. Measuring the influence of incorrect code on test generation. In *Proceedings of the 48th IEEE/ACM International Conference on Software Engineering*, 2026. URL <https://arxiv.org/abs/2409.09464>. Accepted/in press; preprint arXiv:2409.09464.
- Ruanqianqian Huang, Avery Reyna, Sorin Lerner, Haijun Xia, and Brian Hempel. Professional software developers don’t vibe, they control: AI agent use for coding in 2025. *arXiv preprint arXiv:2512.14012*, 2025. doi: 10.48550/arXiv.2512.14012. URL <https://arxiv.org/abs/2512.14012>. Version 2, revised 18 August 2026.
- Yue Jia and Mark Harman. An analysis and survey of the development of mutation testing. *IEEE Transactions on Software Engineering*, 37(5):649–678, 2011. doi: 10.1109/TSE.2010.62.
- Xavier Leroy. Formal verification of a realistic compiler. *Communications of the ACM*, 52(7): 107–115, 2009. doi: 10.1145/1538788.1538814.
- Yunbo Lyu, David Williams, Jieke Shi, Zhensu Sun, Chao Peng, Zhou Yang, Federica Sarro, and David Lo. How do practitioners build SE agents? insights from a mixed-methods study. *arXiv preprint arXiv:2607.10856*, 2026. doi: 10.48550/arXiv.2607.10856. URL <https://arxiv.org/abs/2607.10856>. Version 2, revised 25 July 2026.
- Jeffrey Marron. Implementing the health insurance portability and accountability act (HIPAA) security rule: A cybersecurity resource guide. Technical Report NIST SP 800-66 Rev. 2, National Institute of Standards and Technology, February 2024. URL <https://csrc.nist.gov/pubs/sp/800/66/r2/final>.
- Nat McAleese, Rai Michael Pokorny, Juan Felipe Ceron Uribe, Evgenia Nitishinskaya, Maja Trebacz, and Jan Leike. LLM critics help catch LLM bugs. *arXiv preprint arXiv:2407.00215*, 2024. doi: 10.48550/arXiv.2407.00215. URL <https://arxiv.org/abs/2407.00215>.
- John McCarthy and James Painter. Correctness of a compiler for arithmetic expressions. In *Mathematical Aspects of Computer Science*, volume 19 of *Proceedings of Symposia in Applied Mathematics*, pages 33–41. American Mathematical Society, 1967.

- OWASP Foundation. OWASP Top 10 API Security Risks – 2023. <https://owasp.org/API-Security/editions/2023/en/0x11-t10/>, 2023.
- OWASP Foundation. OWASP Top 10:2025. <https://owasp.org/Top10/>, 2025.
- Amir Pnueli, Michael Siegel, and Eli Singerman. Translation validation. In *Tools and Algorithms for the Construction and Analysis of Systems*, volume 1384 of *Lecture Notes in Computer Science*, pages 151–166, 1998. doi: 10.1007/BFb0054170.
- Damir Safin and Dian Balta. Autonomy and agency in agentic ai: Architectural tactics for regulated contexts. *arXiv preprint arXiv:2605.12105*, 2026. URL <https://arxiv.org/abs/2605.12105>.
- The MITRE Corporation. 2025 CWE Top 25 Most Dangerous Software Weaknesses. https://cwe.mitre.org/top25/archive/2025/2025_cwe_top25.html, 2025.
- U.S. Department of Health and Human Services. Summary of the HIPAA security rule. <https://www.hhs.gov/hipaa/for-professionals/security/laws-regulations/index.html>, 2026. Content last reviewed 7 August 2026; accessed 2 September 2026.
- Boming Xia, Qinghua Lu, Liming Zhu, Zhenchang Xing, Dehai Zhao, and Hao Zhang. Evaluation-driven development and operations of LLM agents: A process model and reference architecture. *arXiv preprint arXiv:2411.13768*, 2025. doi: 10.48550/arXiv.2411.13768. URL <https://arxiv.org/abs/2411.13768>. Version 3, revised 17 November 2025; under review.
- Zhen Xiang, Linzhi Zheng, Yanjie Li, Junyuan Hong, Qinbin Li, Han Xie, Jiawei Zhang, Zidi Xiong, Chulin Xie, Carl Yang, Dawn Song, and Bo Li. GuardAgent: Safeguard LLM agents via knowledge-enabled reasoning. In *Proceedings of the 42nd International Conference on Machine Learning*, volume 267 of *Proceedings of Machine Learning Research*, pages 68316–68342. PMLR, 2025. URL <https://proceedings.mlr.press/v267/xiang25a.html>.
- John Yang, Carlos E. Jimenez, Alexander Wettig, Kilian Lieret, Shunyu Yao, Karthik Narasimhan, and Ofir Press. SWE-agent: Agent-computer interfaces enable automated software engineering. In *Advances in Neural Information Processing Systems*, volume 37, pages 50528–50652, 2024. doi: 10.52202/079017-1601. URL https://proceedings.neurips.cc/paper_files/paper/2024/hash/5a7c947568c1b1328ccc5230172e1e7c-Abstract-Conference.html.
- Xuejun Yang, Yang Chen, Eric Eide, and John Regehr. Finding and understanding bugs in C compilers. In *Proceedings of the 32nd ACM SIGPLAN Conference on Programming Language Design and Implementation*, pages 283–294, 2011. doi: 10.1145/1993498.1993532.
- Simon Yu, Derek Chong, Ananjan Nandi, Dilara Soylu, Jiuding Sun, Christopher D. Manning, and Weiyang Shi. Shepherd: Enabling programmable meta-agents via reversible agentic execution traces. *arXiv preprint arXiv:2605.10913*, 2026. doi: 10.48550/arXiv.2605.10913. URL <https://arxiv.org/abs/2605.10913>. Version 3, revised 24 June 2026.
- Huixuan Zhang, Yun Lin, and Xiaojun Wan. PaCoST: Paired confidence significance testing for benchmark contamination detection in large language models. In *Findings of the Association for Computational Linguistics: EMNLP 2024*, pages 1794–1809, 2024. doi: 10.18653/v1/2024.findings-emnlp.97.

A Implementation Details

Models. Building, pre-merge review and meta-audits used Anthropic Claude models invoked through the Claude Code command-line agent. The multi-model council additionally queried Google Gemini and OpenAI GPT models through their APIs. Reviews and meta-audits were run by separately started agent instances with no access to the development conversation. The reviewing agents shared the builder’s model family, so shared blind spots are possible.